From Network Security to Cloud Security

Cloud Security

CSE4059

Why Is Cloud Security Different?

- The security principles remain, but cloud characteristics change how we apply and maintain controls

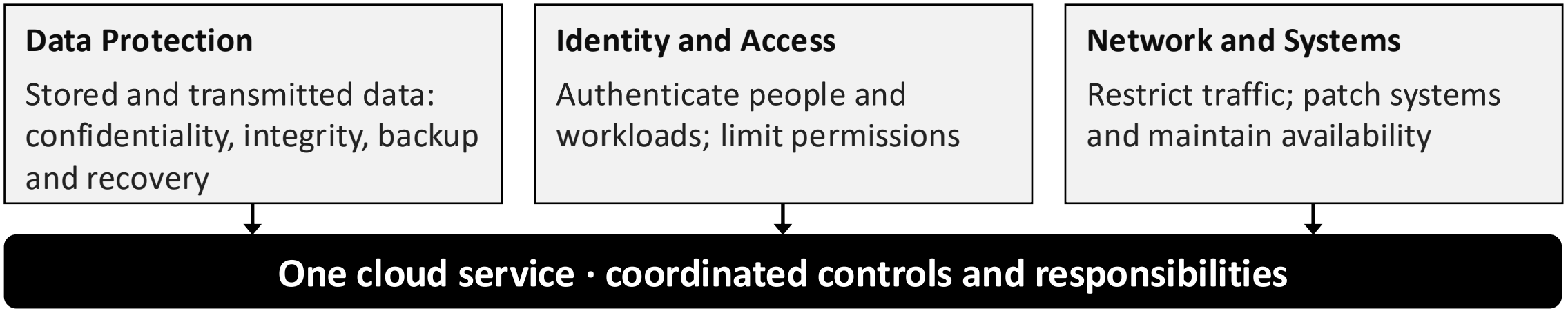
Cloud characteristic	Security implication
On-demand self-service	Control who can create resources and change permissions
Broad network access	Protect network connections and control access to cloud services
Resource pooling	Keep different customer environments isolated
Rapid elasticity	Keep security controls effective as resources scale up or down
Measured service	Monitor resource usage to detect unusual activity or misuse

Cloud security requires:

security mechanisms, secure configuration, and continuous management

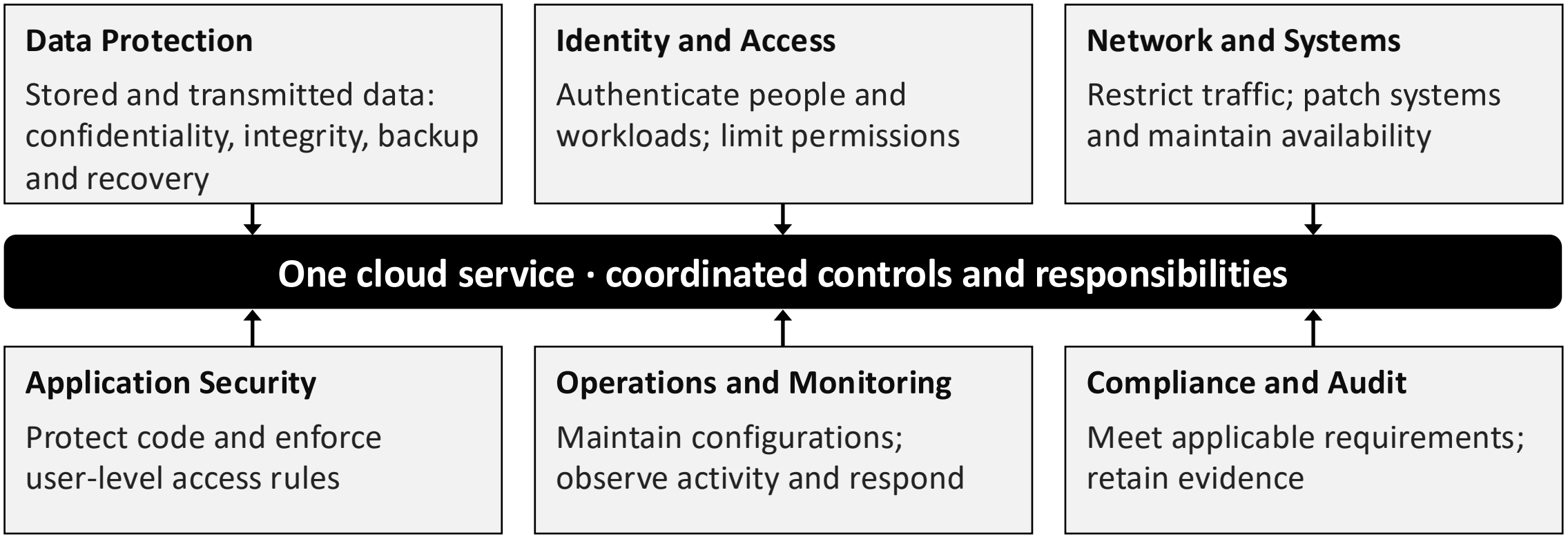
Cloud Security Domains

- Cloud security protects data, applications, and infrastructure through policies, technical controls, and operating procedures



Cloud Security Domains

- Cloud security protects data, applications, and infrastructure through policies, technical controls, and operating procedures



One service needs controls across several areas.. a single mechanism cannot cover them all!

Example: One Report Service



- Alice requests report-1 from the application, which checks her permission
- The application uses its own credentials to request report-1 from the data store
- The data store applies its access policy to decide whether the application may retrieve report-1
- If both checks allow access, the application returns the report to Alice

From Assets to Controls

- Protecting this service requires controls for its reports, application, credentials, and access policies
  - Workload credentials: identify the software
  - Access policies: define which operations each identity may perform

Asset in this service	Threat scenario	Required control
Report data	Unauthorized direct access	Restrict storage access
Web application	Exploitation of vulnerable software	Patching and application security
Workload credentials	Credential theft and misuse	Temporary credentials and least privilege
Report access policies	Overly broad permissions added	Restrict and monitor policy changes

- These requirements guide how we configure the application and storage on AWS

Amazon EC2 and S3

EC2: Run the application

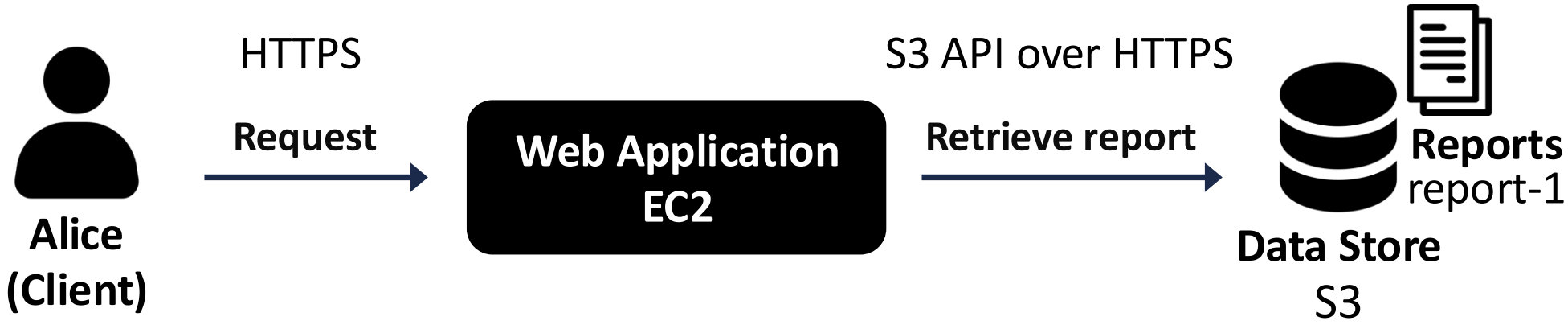
- Amazon Elastic Compute Cloud (EC2) provides virtual servers called instances
- An EC2 instance runs the operating system and hosts the web application

S3: Store report objects

- Amazon Simple Storage Service (S3) stores data as objects in containers called buckets
- An object holds a report and metadata; the application retrieves it through the S3 API

EC2 and S3 provide different services, so their security responsibilities differ

The Report Service using AWS



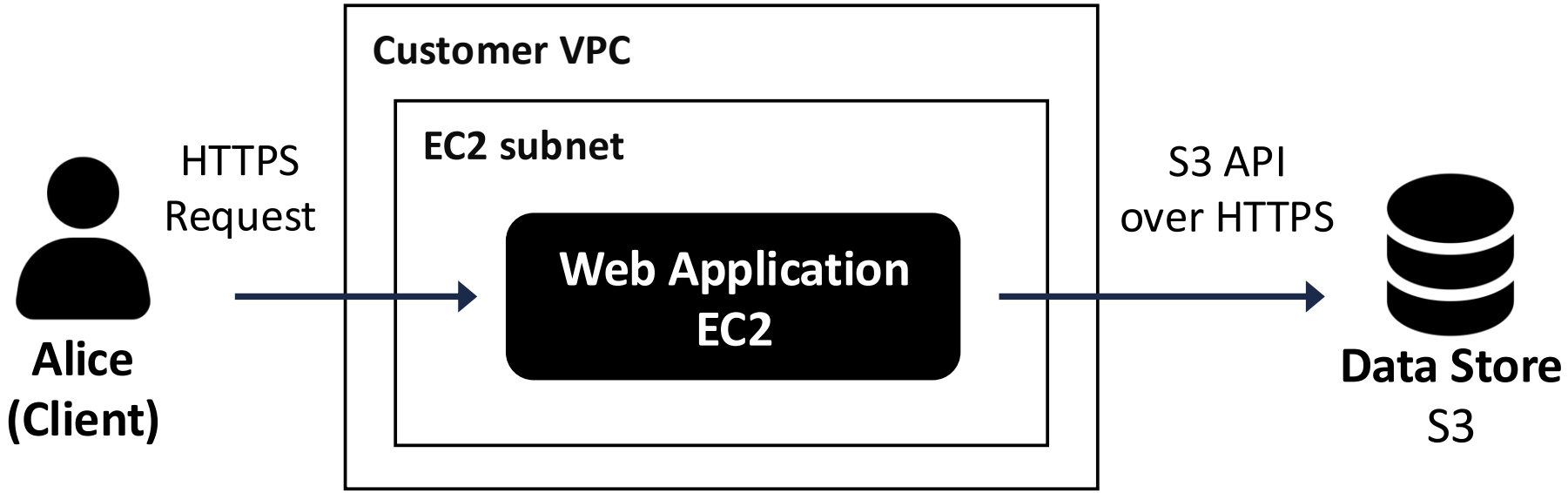
- The application running on EC2 uses the S3 API to retrieve a stored report
  - Client → EC2: HTTPS request to the report application
  - EC2 → S3: a separate HTTPS API request to retrieve report-1

Responsibility in This Deployment

Component / Task	AWS operates	Customer controls
EC2	Physical infrastructure	OS and web application
S3	Internal storage service	Reports and access settings
AWS access policies	Policy enforcement	Who may act on which resource

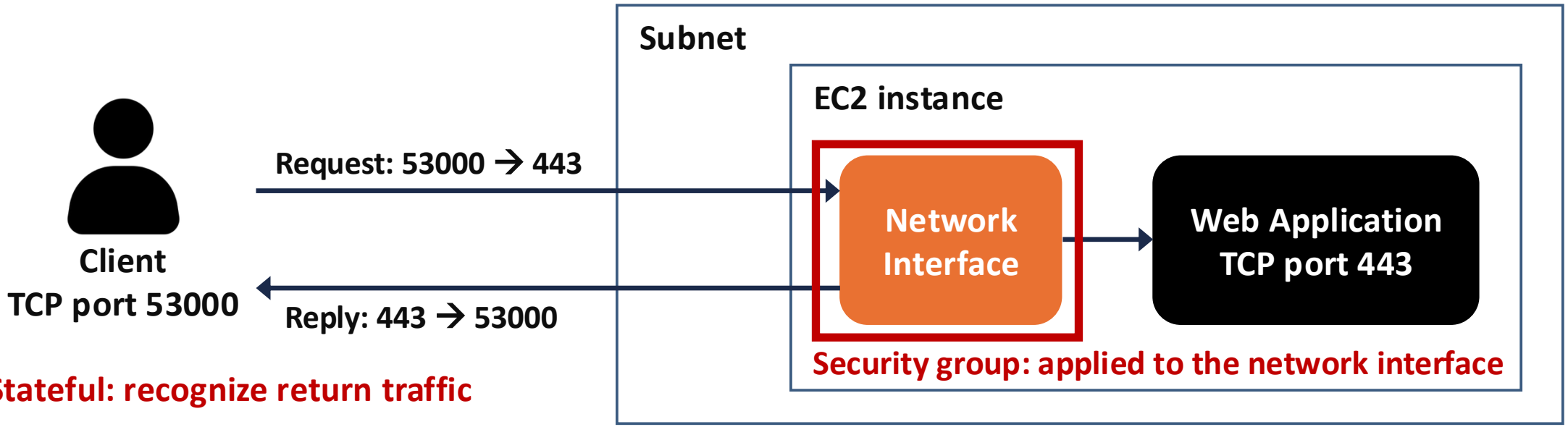
- AWS operates EC2's underlying infrastructure and the internal S3 service
- The customer maintains the EC2 guest OS and application
- The customer configures user authorization, network exposure, workload permissions, and S3 access
- A secure provider does not make the customer's chosen policy correct

Network Placement: VPC and Subnets



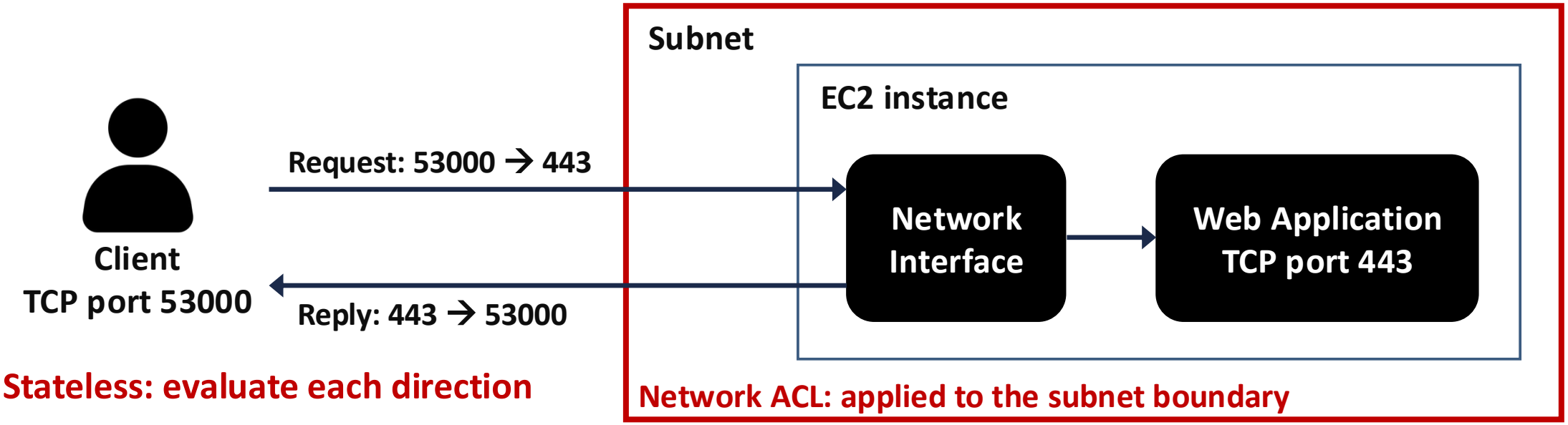
- An Amazon Virtual Private Cloud (**VPC**) is a logically isolated virtual network in AWS
- A **subnet** is an IP address range within a VPC
- EC2 instances are deployed in subnets within a VPC
- Subnets organize resources but do not automatically block communication between them
- “Security Groups” and “Network ACLs” control network traffic

Security Groups: Stateful Filtering



- A security group is an AWS-managed, **stateful** firewall associated with a network interface
- Rules specify permitted traffic – but security groups do not provide explicit deny rules
  - Ex) Allow client TCP connections to application port 443
- Matching return traffic is allowed by the security group without a separate reverse-direction rule
- The security group does not decide whether Alice may read report-1

Network ACLs: Stateless Filtering



- A network Access Control List (ACL) filters traffic entering and leaving a subnet.
- It has allow and deny rules; connection state does not automatically permit replies.
- Both request and return traffic must be allowed by the applicable direction's rules.
- The default network ACL initially allows inbound and outbound traffic; those rules can be changed.
- A security-group allowance does not override a denial at the subnet boundary.

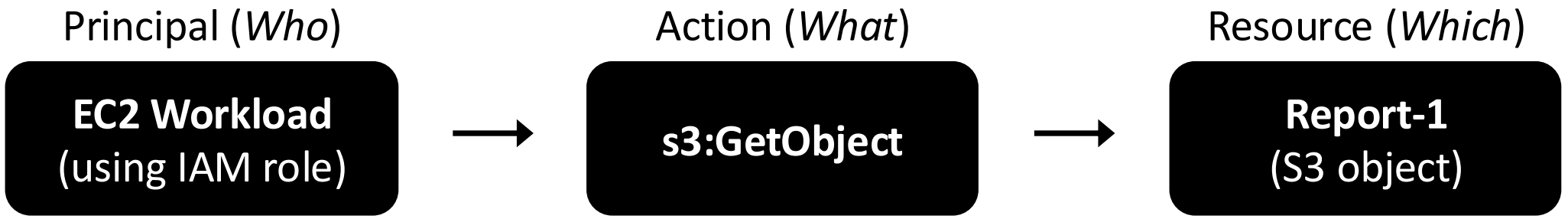
TLS on Both Connections



- Client <-> EC2 and EC2 <-> S3 are separate TLS connections in this example
- The web application acts as a TLS server for Alice and a TLS client for S3
- On each TLS connection, the client authenticates the server
- TLS provides confidentiality and integrity for data in transit
  - Does not determine who is authorized to access an S3 object.

AWS IAM: Resource Authorization

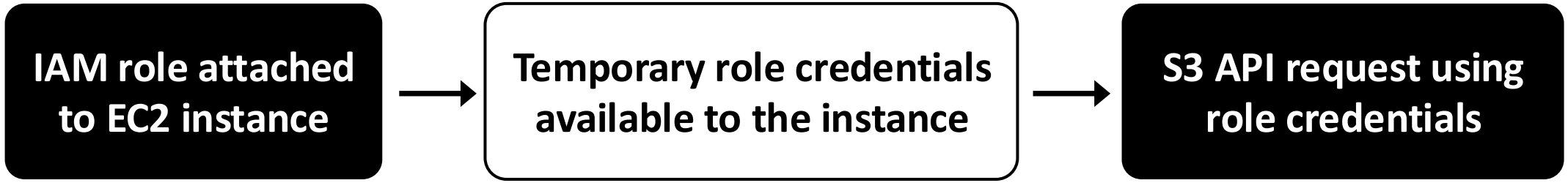
How does AWS decide whether an application can access an S3 object?



- AWS Identity and Access Management (**IAM**) controls access to AWS resources using identities and policies
- IAM policies specify which actions are allowed or denied on which resources, optionally under specific conditions
  - s3:GetObject? the permission action for retrieving an S3 object
- Requests are denied by default unless an applicable Allow exists
  - An applicable explicit Deny overrides any Allow

An IAM Role for the EC2 Instance

How does an application running on EC2 authenticate to AWS?



- An IAM role is an AWS identity with permissions that trusted entities can assume
- The EC2 instance is associated with an IAM role, and AWS provides temporary credentials for that role
- Applications running on the instance can use these credentials to access AWS services, such as S3
- Using IAM role credentials avoids hard-coding long-term access keys, while least privilege limits what the workload can do

Policies for S3 Access

How do we define who can access the reports stored in S3?

Identity-based policy

- Attached to an IAM identity (ex. an IAM role used by EC2)
- Defines which actions the identity may perform on which resources

Resource-based policy

- Attached to a resource (ex. S3 bucket)
- Specifies which principals can access the resource and what actions they can perform

- Both policy types can control access to S3 objects, but they are attached to different targets: IAM identities and S3 buckets
- AWS evaluates applicable policies to determine whether a request is allowed or denied.

Two Authorization Decisions

Does the EC2 role's S3 permission mean that every application user can read the report?



Alice: Allowed / Bob: Denied

- Application authorization
  - Alice may read report-1, but Bob may not
- AWS resource authorization
  - The EC2 role has s3:GetObject permission for report-1
- S3 evaluates the EC2 role's request, not Alice's or Bob's application-level permissions
- The web application must reject Bob's request, even though its EC2 role can retrieve the object

One Request, Several Decisions

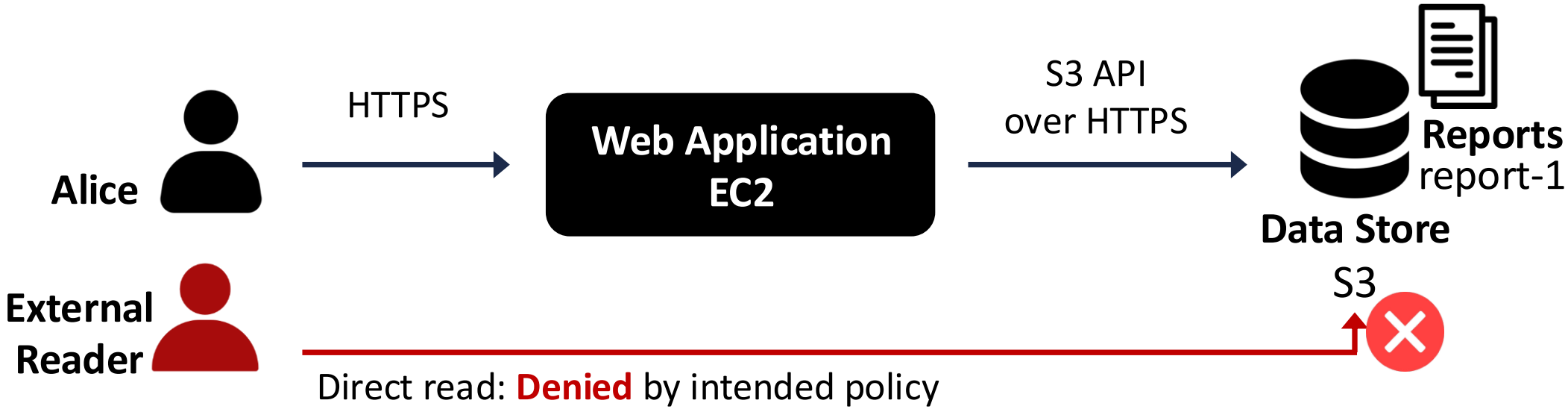
What security checks are involved when Alice requests report-1?

Control	Question	Decision scope
Network filtering	Is the required traffic allowed?	Network traffic
TLS	Is each connection authenticated and protected?	Each TLS connection
Application authorization	May Alice read report-1?	User and report
AWS IAM / S3 authorization	Can the EC2 role retrieve report-1?	Role, action, and object

- Passing one security check does not replace the others

The Intended Access Boundary

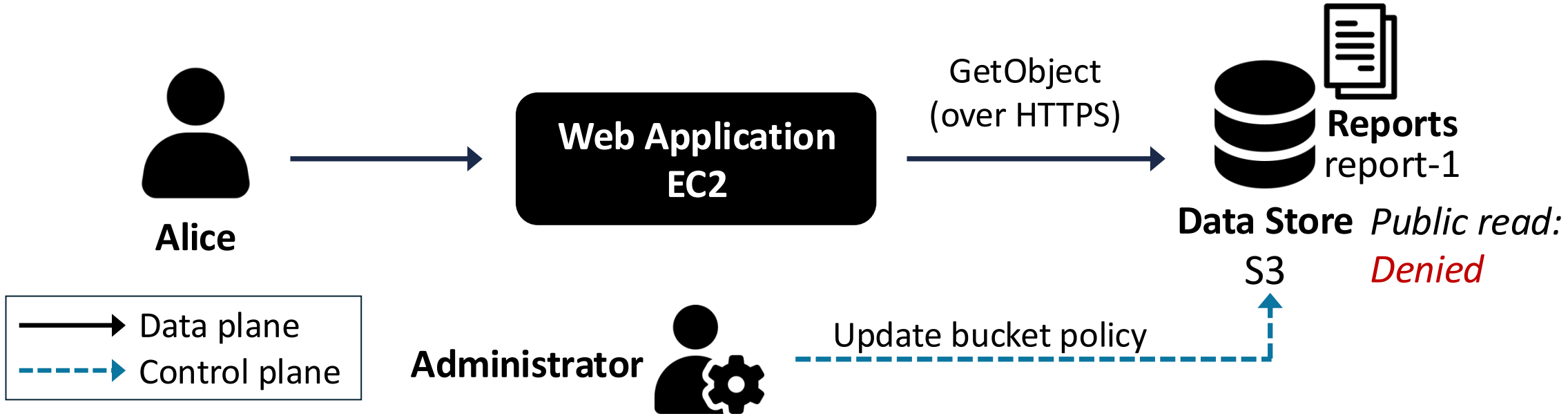
Can someone bypass the web application and retrieve report-1 directly from S3?



- Alice may access report-1 through the web application after an authorization check
- The web application uses the EC2 IAM role to retrieve report-1 from S3
- An unauthenticated external reader must be denied when requesting report-1 directly from S3
- The application's authorization check cannot protect requests made directly to S3

Who can Change the S3 Access Rules?

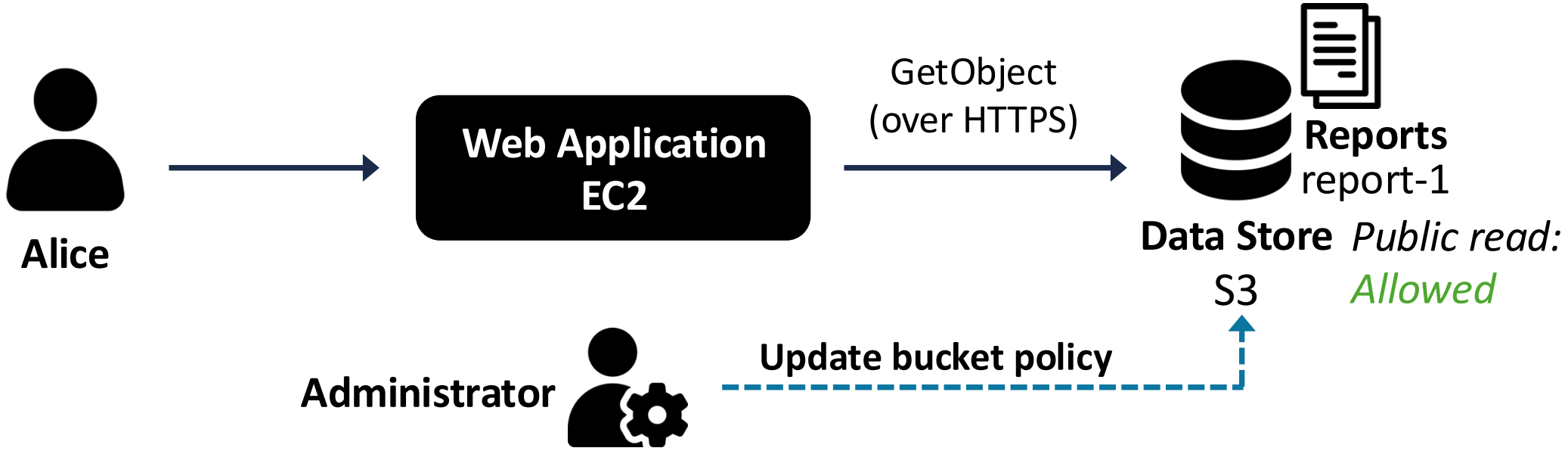
How can an administrator change who is allowed to read the reports?



- Data Plane: The application retrieves report-1 from S3 using GetObject
- Control Plane: An administrator updates the S3 bucket policy to change access permissions
- Security implication: A control plane change can affect which subsequent data plane requests are allowed

A Policy Change Exposes the Report

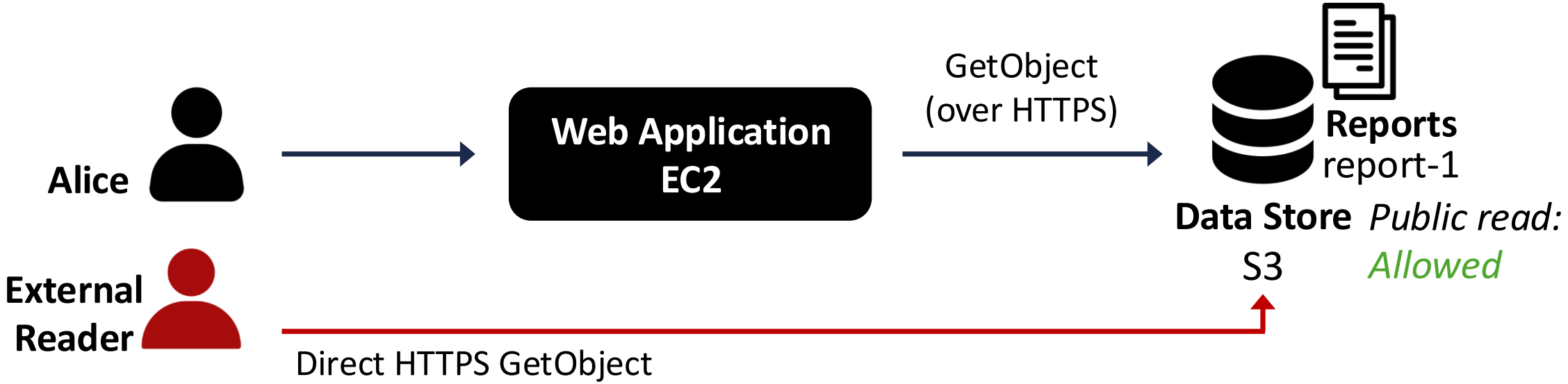
What happens if an administrator accidentally grants public access to a confidential report?



- An administrator mistakenly updates the S3 bucket policy to allow anyone to read report-1
- An external user can now retrieve the report directly from S3
- The web application's authorization rules remain unchanged

A Read That Bypasses the Application

What happens after the bucket policy allows public access?



- An external reader can retrieve report-1 directly from S3
- This request does not go through the web application or its EC2 security group
- TLS still protects the communication, but the report is delivered to an unintended reader

Correct the Access Configuration

How can we fix the exposure without breaking legitimate access?



- Remove the unintended public-read permission from the S3 bucket policy
- Preserve the EC2 role's required access to report-1
- Restrict who can modify the bucket policy
- Verify that authorized reads succeed and unauthorized direct reads are denied

Configuration Drift

Can a secure configuration become insecure over time?

- Scenario
  - After fixing the S3 exposure, an administrator temporarily grants a Test Role access to report-1 for testing, but forgets to remove the permission

Access request	Expected after testing	Actual
EC2 Role → GetObject	Allow	Allow
Test Role → GetObject	Deny	Allow

- Configuration drift occurs when the current configuration differs from the intended configuration
- The temporary permission remains in the S3 bucket policy after testing
- The application still works, but access permissions are broader than intended

CloudTrail: Changes and Data Access

How can we trace changes to access permissions and subsequent data access?

Management Events	Data Events
• Record operations that manage AWS resources and their configurations • e.g., An administrator changes an S3 bucket policy	• Record operations performed on data within AWS resources • e.g., A Test Role retrieves an S3 object

- AWS **CloudTrail** records supported AWS API activity as events
- Management Events help identify who changed a resource and when
- Logging access to individual S3 objects (ex. GetObject) must be explicitly enabled in CloudTrail
- Logging provides evidence, but does not automatically detect or prevent security problems

Verify the Intended Behavior

How can we verify that our security controls work as intended?

Test request	Expected result	What it verifies
Alice: reads report-1 via the application	Allow	Application authorization
Bob: reads report-1 via the application	Deny	Application authorization
EC2 role: reads report-1 from S3	Allow	Required workload permission
Test role: reads report-1 from S3	Deny	Temporary permission removed
External reader: accesses S3 directly	Deny	Public access restricted

- Test *both* allowed and denied requests to verify the intended access controls
- Confirm which control makes each authorization decision
- Verify that the relevant activities are logged by CloudTrail

Summary

- The same security principles apply in the cloud, but controls are implemented and managed differently
- Network filtering, TLS, and authorization protect different aspects of the same service
- Application-level authorization and AWS IAM permissions are separate decisions
- Misconfigured access policies can expose data even when other security controls work correctly
- Security requires ongoing verification
- **Starting next week**
  - Tuesday: lecture / Thursday: lab session